

Security Evaluation Matrix

Research Objective	Functional Output / Module	Functionality Evaluation	STRIDE Threat	Security Test / Metric (OWASP Top 10:2025)	Expected Chapter 4 Evidence
Develop secure user authentication and account management for authorized users	Login / User Management Module	Functional Suitability, Usability	Spoofing	Invalid Login Blocking, Account Lockout, Role-Based Access Restriction	Authentication Security Results
Develop secure data entry and student record management features	Records / Database Management Module	Functional Correctness, Reliability	Tampering	Unauthorized Record Modification Detection, Input Validation Accuracy, Record Integrity Checking	Input Validation Results
Implement audit logs and monitoring mechanisms for accountability	Logs / Monitoring Module	Reliability, Functional Suitability	Repudiation	Activity Log Completeness, User Action Tracking Accuracy, Monitoring Reliability	Logging & Monitoring Results
Protect sensitive student records and assessment data	Reports / Protected Records / Session Controls	Reliability, Functional Correctness	Information Disclosure	Access Permission Validation, Unauthorized Access Blocking Rate, Secure Data Handling	Data Protection Results
Maintain system continuity during interruptions	Core Services / Offline Framework	Performance Efficiency, Availability	Denial of Service	LAN Accessibility, Offline Stability, Recovery	Availability Results
Enforce secure session handling	Session Management	Functional Correctness, Reliability	Elevation of Privilege	Session Timeout Enforcement, Access Restriction	Session Security Results

Backup
Cache

section 5

section 4

Availability Results

Session Security Results

section 1

LENLEARN

Administrator Security Evaluation Post-Questionnaire

Instructions

Please rate each statement based on your experience managing and using the LENLEARN LMS. Place a check (✓) in the box that best represents your assessment. This questionnaire covers all 7 modules of the Security Evaluation Matrix aligned with the OWASP Top 10:2025 and STRIDE threat model.

Rating Scale

5 Strongly Agree	4 Agree	3 Neutral	2 Disagree	1 Strongly Disagree
----------------------------	-------------------	---------------------	----------------------	-------------------------------

Respondent Information

Name (optional): _____	Role / Position: <u>cyber admin</u> ☒ ☐ ☐ ☐ ☐	Date: _____
------------------------	--	-------------

Section 1: Authentication Security

No.	Statement	5	4	3	2	1
1	The login process allows access only to authorized administrators. ✓	☐	☐	☐	☐	☐
2	The system properly blocks invalid login attempts and enforces account lockout after repeated failures. ✓	☐	☐	☐	☐	☐
3	Password requirements (minimum length, complexity) are enforced when creating or updating accounts. ✓	☐	☐	☐	☐	☐
4	The account lockout mechanism activates after 5 consecutive failed login attempts. ✓	☐	☐	☐	☐	☐
5	The system protects administrator credentials and never exposes them in API responses or logs. <u>Test cage</u>	☐	☐	☐	☐	☐

Section 2: Access Control

No.	Statement	5	4	3	2	1
6	User roles (admin, faculty, student) are properly restricted across all system modules. <u>RBAC</u>	☐	☐	☐	☐	☐
7	Only authorized users can access sensitive records and administrative pages. <u>redundant</u>	☐	☐	☐	☐	☐
8	The system prevents unauthorized modification of student or faculty records. <u>redundant</u>	☐	☐	☐	☐	☐
9	Administrative permissions are properly enforced and cannot be bypassed. <u>redundant</u>	☐	☐	☐	☐	☐
10	The system blocks privilege escalation — users cannot change their own role or permissions. <u>redundant</u>	☐	☐	☐	☐	☐

Section 3: Input Validation & Injection Prevention

No.	Statement	5	4	3	2	1
11	The system rejects SQL injection attempts in all input fields. <i>Test Case</i>	☐	☐	☐	☐	☐
12	The system blocks cross-site scripting (XSS) attempts in text inputs and form fields. <i>Test Case</i>	☐	☐	☐	☐	☐
13	Student and faculty records are protected from unauthorized modification through the interface. <i>Test Case</i>	☐	☐	☐	☐	☐
14	The system validates all data before saving records to the database. <i>password</i>	☐	☐	☐	☐	☐
15	Record changes are tracked with the identity and timestamp of the user who made them. ✓	☐	☐	☐	☐	☐

Section 4: Data & Cryptographic Protection

No.	Statement	5	4	3	2	1
16	Student records are securely stored and protected from unauthorized viewing.	☐	☐	☐	☐	☐
17	Sensitive information (passwords, tokens, secret fields) is never exposed in system responses.	☐	☐	☐	☐	☐
18	Teachers can only view records of students assigned to their own sections.	☐	☐	☐	☐	☐
19	The system securely handles uploaded files and restricts access to authorized users only.	☐	☐	☐	☐	☐
20	User passwords are properly hashed and never stored or transmitted in plaintext.	☐	☐	☐	☐	☐

Section 5: Security Logging & Alerting

No.	Statement	5	4	3	2	1
21	The system records all important user activities (login, logout, record changes) in the audit log.	☐	☐	☐	☐	☐
22	Failed login attempts are logged with timestamps for investigation.	☐	☐	☐	☐	☐
23	The system can trace user actions accurately when a security incident needs to be investigated.	☐	☐	☐	☐	☐
24	Audit logs are protected from deletion or tampering by regular admin users.	☐	☐	☐	☐	☐
25	Suspicious activity patterns (e.g., repeated failed logins) are captured and visible in logs.	☐	☐	☐	☐	☐

Section 6: Session Management

No.	Statement	5	4	3	2	1
26	The system automatically logs out users after a defined period of inactivity. <i>Reported</i>	☐	☐	☐	☐	☐
27	Session cookies are secured with HttpOnly and Secure flags to prevent theft.	☐	☐	☐	☐	☐
28	Logging out properly invalidates the session on the server and prevents reuse.	☐	☐	☐	☐	☐
29	Users cannot access protected pages after their session has expired.	☐	☐	☐	☐	☐
30	The system prevents session hijacking by enforcing secure session token handling.	☐	☐	☐	☐	☐

Section 7: System Reliability & Security Configuration

No.	Statement	5	4	3	2	1
31	The system remains stable and accessible during regular multi-user operations.	☐	☐	☐	☐	☐
32	Security headers (X-Frame-Options, Content-Security-Policy, HSTS) are correctly configured. <i>heavy</i>	☐	☐	☐	☐	☐
33	The system is accessible over the local area network (LAN) without performance issues. <i>cache</i>	☐	☐	☐	☐	☐
34	Rate limiting prevents excessive requests from overloading the system.	☐	☐	☐	☐	☐
35	Error messages are informative for users but never expose internal server details or stack traces.	☐	☐	☐	☐	☐

Section 8: Interface, Integrity & Error Handling

No.	Statement	5	4	3	2	1
36	Security features (lockout, timeout) do not unnecessarily disrupt normal administrative tasks.	☐	☐	☐	☐	☐
37	Destructive actions (delete, archive, bulk operations) require explicit confirmation before executing.	☐	☐	☐	☐	☐
38	The dashboard makes it easy to navigate between modules without exposing sensitive data.	☐	☐	☐	☐	☐
39	The system handles unexpected errors gracefully without crashing or leaking internal information.	☐	☐	☐	☐	☐
40	Overall, the system interface supports secure, reliable, and efficient administration.	☐	☐	☐	☐	☐